Activepieces Open Source: Security & Compliance Validation

Purpose: Pre-adoption validation to ensure clarity on licensing, security, and compliance before proceeding with Activepieces.
Date: February 2025

Executive Summary

Aspect	Assessment	Risk Level
License (CE only)	Safe for commercial use under MIT	Low
License (EE features)	Requires paid subscription for production	Medium (if misused)
Security posture	Established process; self-hosted control	Low–Medium
Terms of Service	Primarily for SaaS/Enterprise; MIT preserved	Low
Compliance	Clear boundaries; follow checklist	Low

Conclusion: Activepieces Community Edition is safe to use under the MIT license for self-hosted deployment with `AP_EDITION=ce`. Enterprise features require a commercial license.

1. License Validation

1.1 Community Edition (MIT) – Safe to Use

- **License:** MIT Expat (root `LICENSE`)
- **Scope:** All code outside `packages/ee/` and `packages/server/api/src/app/ee/`
- **Rights:** Use, modify, merge, publish, distribute, sublicense, sell
- **Obligation:** Include copyright notice and license text when distributing

Validation: MIT is widely used and commercially acceptable. No restrictions on internal or commercial use for CE.

1.2 Enterprise Edition – Commercial License

- **License:** Commercial (see `packages/ee/LICENSE`)
- **Production use:** Requires valid subscription and compliance with Activepieces Terms
- **Dev/Test:** Free – "you may copy and modify the Software for development and testing purposes, without requiring a subscription"

Validation: EE is optional. Do not use `AP_EDITION=ee` or `AP_EDITION=cloud` in production without a license.

1.3 Terms of Service Clarification

From Terms §5.6:

> "Portions of the Software are governed by underlying open source licenses... This Agreement... **are not intended to limit Customer's right to software code under the terms of an open source license**."

Validation: MIT rights are not overridden by the commercial terms. Terms primarily govern SaaS and Enterprise subscriptions.

1.4 Key License Risks & Mitigations

Risk	Mitigation
Accidentally using EE in production	Use `AP_EDITION=ce` (default); never set `ee` or `cloud` without a license
Distributing modified code	Include MIT notice and `LICENSE` file
Fork modifications touching EE	Avoid changing EE code unless licensed; CE modifications are MIT
Third-party dependencies	Run `bun audit` / `npm audit`; check dependency licenses

1.5 CE Code Modification & Use Labels

Can You Modify CE Code?

Yes. Under the MIT license, you may freely modify all Community Edition code (everything outside `packages/ee/` and `packages/server/api/src/app/ee/`).

Explicit MIT rights include:

- Use, copy, modify, merge, publish, distribute, sublicense, and/or sell copies
- Use for internal or commercial purposes

Restrictions When Modifying

Restriction	Requirement
Attribution	When distributing (publishing, sharing, or selling copies), you must include the copyright notice and permission notice in all copies or substantial portions of the Software
No warranty	Software provided "AS IS"; no warranty or liability from authors
EE code	Do not modify or rely on EE code for production without a commercial license

CE vs EE Modification Boundaries

Area	License	Can Modify?	Restrictions
Core (non-EE) code	MIT	Yes	Include copyright + license when distributing
`packages/pieces/` (including custom pieces)	MIT	Yes	Same as above
`packages/ee/` and `packages/server/api/src/app/ee/`	Commercial	Dev/Test only*	Production use requires license; modifications belong to Activepieces

*EE license allows modification for development and testing without a subscription; production use of EE requires a license.

Use Labels & Branding

Requirement	CE	EE
"Powered by Activepieces"	Not required	Optional (controlled by `showPoweredBy` in license)
Visible branding/labels	Not required	May be required per license terms
Rebranding allowed	Yes	Depends on license
License notice in source	Required when distributing	Required when distributing

Summary: CE has no forced attribution labels or "Powered by" requirements. You may rebrand the UI. You must retain the copyright and license notice in the source code when distributing.

Quick Checklist for CE Modifications

Action	Requirement
Modify CE code	Allowed
Use internally (no distribution)	No extra obligations beyond retaining notices in source
Redistribute or publish your fork	Include root `LICENSE` file and copyright notice
Rebrand UI / remove logos	Allowed
Add "Powered by" badge	Optional; not required for CE
Modify EE code for production	Requires commercial license

1.6 Validating Your Code Changes (License Compliance)

Use the following to verify your modifications do not violate the MIT or EE license terms.

Automated Validation Script

Run the license compliance validator before committing or distributing:

```
./scripts/validate-license-compliance.sh
```

What it checks:

Check	Purpose	Severity
Root `LICENSE` exists	Required when distributing; must contain copyright + MIT notice	FAIL
`packages/ee/LICENSE` exists	If EE code is present, its license must be retained	FAIL
Modified EE files	**DANGER** – Your changes must be MIT only; EE changes require commercial license	DANGER (exit 1)
`AP_EDITION` in env files	Warns if set to `ee` or `cloud` (requires commercial license)	Warning
MIT attribution clause	Confirms required "permission notice" is present in LICENSE	FAIL

Severity:

- **FAIL** – Validation fails; fix before proceeding
- **DANGER** – EE-licensed files modified; validation fails. Revert EE changes to stay MIT-only
- **Warning** – Informational; does not fail unless `--strict`

Options:

- `--strict` : Exit with error on warnings (useful for CI)
- `--verbose` / `-v` : Show which license (MIT vs EE) applies to each modified file
- `-h` / `--help` : Show usage

Manual Validation Checklist

Use this checklist when you cannot run the script or want to double-check:

- ☐ **LICENSE file:** Root `LICENSE` exists and includes "Copyright (c) 2020-2024 Activepieces Inc." and the MIT permission notice
- ☐ **EE license:** If `packages/ee/` or `packages/server/api/src/app/ee/` exist, `packages/ee/LICENSE` is present
- ☐ **EE modifications:** If you changed EE code, you have a commercial license for production, or changes are dev/test only
- ☐ **AP_EDITION:** Set to `ce` for Community Edition (no license needed)
- ☐ **Distribution:** If publishing your fork, include `LICENSE` (and `packages/ee/LICENSE` if EE code is included)

Common Violations to Avoid

Violation	How to Avoid
Removing LICENSE when distributing	Keep the root `LICENSE` file in your repo and any distributed copy
Removing copyright notice	Do not delete or obscure "Copyright (c) 2020-2024 Activepieces Inc." from LICENSE
Using EE in production without license	Use `AP_EDITION=ce` ; obtain license from sales@activepieces.com if you need EE
Distributing EE modifications without license	Do not distribute modified EE code without a commercial agreement

When to Run Validation

- **Automatically before every commit** – A pre-commit hook runs the validator (see `.husky/pre-commit`)
- Before creating a release or tag
- Before publishing a fork or Docker image
- In CI/CD pipeline (use `--strict` for automated gates)

Skipping the Pre-Commit Hook (Emergency Only)

To bypass the hook once (e.g., for a WIP commit that you will fix):

```
git commit --no-verify -m "your message"
```

Warning: Use sparingly. Do not commit EE changes without a license.

1.7 Am I Violating the EE License?

Use this decision flow to determine if your use violates the EE license.

EE License Violation Checklist

Scenario	Violating EE?	Explanation
Using `AP_EDITION=ce` (default) in production	**No**	CE mode does not enable EE features; EE code is present but not used for commercial functionality
Using `AP_EDITION=ee` or `cloud` in production without a license	**Yes**	EE license explicitly requires a valid subscription for production use
Modifying EE code for development or testing only	**No**	EE license allows "copy and modify for development and testing purposes without requiring a subscription"
Modifying EE code and using in production without license	**Yes**	Production use of EE (including modified EE) requires a valid license
Distributing your fork that includes unmodified EE code	**Risky**	EE license forbids "copy, merge, publish, distribute, sublicense, and/or sell" without a license. Including EE in a public fork may be considered distribution. Use CE-only or obtain a license.
Distributing your fork with modified EE code	**Yes**	Definitely violates EE license without a commercial agreement
Modifying only MIT (non-EE) code	**No**	Your modifications are under MIT; no EE license applies to your changes
Running the app with EE code in repo but `AP_EDITION=ce`	**No**	EE modules are not registered; you are using CE functionality only

EE License Violation – Summary of "Forbidden" Acts

From packages/ee/LICENSE:

> "Subject to the foregoing, it is forbidden to **copy, merge, publish, distribute, sublicense, and/or sell** the Software [EE code]."

You are violating EE license if you:

1. Use `AP_EDITION=ee` or `AP_EDITION=cloud` in production without a valid Activepieces Enterprise license
2. Publish, distribute, sublicense, or sell EE code (or a product containing modified EE code) without a commercial agreement
3. Modify EE code and use it in production without a license (dev/test only is allowed)

You are NOT violating EE license if you:

1. Use `AP_EDITION=ce` in production (CE only)
2. Modify EE code solely for development and testing on your own machine
3. Use the repo as-is with CE, without distributing modified EE code

1.8 Which License Applies to My Changes?

Your changes are governed by the license of the **files you modified**, not by the whole project.

License by File Path

Files You Modified	License That Applies	Your Rights
`packages/ee/**`	EE (Commercial)	Dev/test only without subscription; production requires license; modifications belong to Activepieces
`packages/server/api/src/app/ee/**`	EE (Commercial)	Same as above
Everything else (e.g. `packages/shared/`, `packages/pieces/`, `packages/react-ui/`, `packages/server/api/src/app/*` excluding `ee/`)	MIT	Use, modify, distribute; include copyright + license when distributing

Quick Reference: License by Directory

Path	License	Your Changes Governed By
`packages/ee/`	EE (Commercial)	EE license
`packages/server/api/src/app/ee/`	EE (Commercial)	EE license
`packages/shared/`	MIT	MIT
`packages/pieces/` (including `custom/`)	MIT	MIT
`packages/react-ui/`	MIT	MIT
`packages/engine/`	MIT	MIT
`packages/server/api/src/app/` (excluding `ee/`)	MIT	MIT
`docs/`, `scripts/`, root files	MIT	MIT

Mixed Changes (Both MIT and EE)

If you modified files in both MIT and EE paths:

Your Changes	License for Your Work	What to Do
MIT files only	MIT	You may distribute under MIT; include LICENSE
EE files only	EE	Do not use in production or distribute without license; dev/test OK
Both MIT and EE	Mixed	MIT parts: distribute under MIT. EE parts: do not distribute or use in production without license

How to Check Which License Applies to Your Changes

Run the validation script—it reports which paths you modified:

```
./scripts/validate-license-compliance.sh --verbose
```

Or manually, with git:

```
# List modified files (working tree + staged)
git status --short
git diff --name-only HEAD

# Check if any are under EE paths
git diff --name-only HEAD | grep -E "^packages/ee/|^packages/server/api/src/app/ee/"
# If output is empty → all your changes are MIT-licensed
# If output has files → those changes are under EE license
```

2. Security Validation

2.1 Security Posture

- **Disclosure:** security@activepieces.com
- **Policy:** Documented in `docs/project/SECURITY.md`
- **Response:** Aim to respond within 3 business days
- **Self-hosted:** Data stays in your environment; no mandatory upstream data sharing

2.2 Security Considerations

Area	Status	Notes
Vulnerability disclosure	Documented	Responsible disclosure process in place
Known CVEs	No major public advisories found	Check NVD/CVE and GitHub Security regularly
Dependency audit	Recommended	Run `bun audit` or `npm audit` periodically
Authentication	Built-in	Supports email, OAuth; EE adds SSO/SAML
Data handling	Self-hosted	Your DB; ensure proper encryption, backups, access controls

2.3 Recommended Security Practices

1. Run dependency audits: `bun audit` or `npm audit`
2. Keep environment variables secure: `AP_JWT_SECRET`, `AP_ENCRYPTION_KEY`, DB credentials
3. Use HTTPS in production
4. Restrict network access (firewall, VPN) for the app and DB
5. Monitor releases and security advisories: GitHub, Changelog

2.4 Telemetry

- **Default:** Telemetry enabled
- **Data:** Usage metrics; no personal information per docs
- **Opt-out:** `AP_TELEMETRY_ENABLED=false`
- **Code:** `packages/shared/src/lib/common/telemetry.ts`

3. Compliance Checklist

Pre-Production

- [ ] Confirm `AP_EDITION=ce` for Community-only use
- [ ] Read and retain root `LICENSE` and `packages/ee/LICENSE`
- [ ] Run dependency audit (`bun audit` or `npm audit`)
- [ ] Decide on telemetry: enable or set `AP_TELEMETRY_ENABLED=false`
- [ ] Document your deployment and data handling for internal compliance

If Using Enterprise Features

- [ ] Obtain license from sales@activepieces.com
- [ ] Agree to Activepieces Terms
- [ ] Comply with user/seat limits and payment terms

If Distributing Modified Code

- [ ] Include MIT copyright notice and license text
- [ ] If EE code is included, include `packages/ee/LICENSE` and respect its terms
- [ ] Retain third-party license notices

If Forking

- [ ] Keep CE changes under MIT
- [ ] Do not modify or redistribute EE code without a license
- [ ] Maintain clear attribution to Activepieces

4. Risk Summary

Low Risk (CE, Self-Hosted)

- Use of Community Edition under MIT
- Self-hosted deployment with `AP_EDITION=ce`
- Custom pieces in `packages/pieces/custom/` (MIT)
- Internal use and modification of CE code

Medium Risk (Mitigatable)

- Dependency vulnerabilities → Mitigate with regular audits
- Telemetry → Mitigate with `AP_TELEMETRY_ENABLED=false` if needed
- Outdated versions → Mitigate with upgrade policy

High Risk (Avoid)

- Using `AP_EDITION=ee` or `cloud` in production without a license
- Distributing EE code or modifications without a commercial agreement
- Removing or obscuring license notices when distributing

5. Recommendations

1. **Use Community Edition only** unless you have an Enterprise license.
2. **Pin `AP_EDITION=ce`** in deployment config to avoid accidental EE use.
3. **Maintain an adoption log** (version, edition, deployment date, compliance actions).
4. **Perform periodic audits** of dependencies and security advisories.
5. **Confirm with Legal** if you have specific regulatory or contractual constraints.

6. References

- License
- Terms of Service
- Root LICENSE
- EE LICENSE
- Security Contact
- Telemetry Config
- LICENSE_COMPLIANCE.md (detailed license mapping)

This document provides guidance only and does not constitute legal advice. Consult legal counsel for your specific situation.